

SIMATS ENGINEERING
ASSESSMENT TOOL III – Penetration testing Task

Course:	Code:	CO: CO3
Duration: 90 min	Total Marks: 50	Reg No / Name :

COURSE OUTCOME COVERED

CO3: *Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BL4)*

Duration: 90 min

Instructions: Answer all questions. Each question carries 10 marks.

1. An organization has commissioned an external penetration test to determine how much information an unauthorized attacker could gather about its internet-facing infrastructure without directly attacking its systems. Using the **theHarvester** tool against the authorized domain **tesla.com**, conduct a comprehensive reconnaissance exercise to identify publicly available email addresses, subdomains, hostnames, IP addresses, URLs, and other relevant infrastructure information. Organize and analyze the collected information to determine how it contributes to the external attack surface, including the risks associated with exposed employee information, unnecessary subdomains, hostnames, and externally hosted services. Finally, prepare a security assessment explaining the information discovered, the most valuable reconnaissance findings, how multiple pieces of information could be combined by an attacker, the associated risks, recommended controls to reduce information disclosure, and which findings should be validated during subsequent penetration-testing phases. **Required Tool: theHarvester.**

Ans: External Reconnaissance and Attack Surface Assessment Using theHarvester

1. Objective

- Identify publicly available information about tesla.com.
- Understand the organization's external attack surface.

2. Tool Used

- **theHarvester**
- Used for passive OSINT reconnaissance.

3. Information Collected

- Email addresses
- Subdomains
- Hostnames
- IP addresses
- URLs
- Publicly exposed infrastructure
- Third-party services

4. Basic Command

`theHarvester -d tesla.com -b crtsh,certspotter`

5. Email Address Risks

- Can be used for targeted phishing.
- Helps identify employees and departments.

- May reveal organizational naming patterns.

6. Subdomain Risks

- Unnecessary subdomains increase the attack surface.
- dev, test, admin, and legacy systems may have weaker security.
- Forgotten subdomains may expose outdated services.

7. Hostname and IP Risks

- Help attackers map external infrastructure.
- Can reveal potentially accessible services.
- IP-to-hostname relationships provide useful reconnaissance information.

8. Third-Party Service Risks

- Misconfigured cloud or external services may expose information.
- Abandoned services can create security risks.

9. Most Valuable Findings

- Administrative portals
- Development/testing systems
- Legacy systems
- Authentication portals
- Employee email addresses
- Unexpected external services

10. How Attackers Combine Information

- Email → employee identification → phishing.
- Subdomain → hostname → IP → service identification → vulnerability research.

11. Recommended Security Controls

- Maintain an external asset inventory.
- Remove unused subdomains and services.
- Secure development/testing environments.
- Use MFA for administrative systems.
- Monitor DNS and certificate changes.
- Review third-party/cloud services regularly.
- Minimize unnecessary public employee information.

12. Findings to Validate

- Internet-facing admin systems
- Development/test environments
- Legacy hosts
- Cloud/third-party services
- Exposed authentication portals
- Potentially vulnerable services

13. Conclusion

- theHarvester helps identify publicly exposed information without directly attacking systems.
- Individual findings may appear harmless, but combining them can significantly improve an attacker's understanding of the target.
- High-value findings should be manually verified and tested during later authorized penetration-testing phases.

```

kali@kali -
Session Actions Edit View Help
-q, --quiet          Suppress missing API key warnings.
-b, --source SOURCE   baidu, bevigil, Bing, BingAPI, brave, bufferoverrun, builtwith, censys, certspotter, criminalip, crtsh, dehashed, dnsdumpster,
                        duckduckgo, fullhunt, github-code, hackertarget, haveibeenpwned, hunter, hunterhow, intelx, leaklookup, netlas, onyphe, otx,
                        pentesttools, projectdiscovery, rapiddns, rocketreach, securityscorecard, securitytrails, shodan, sitedossier, subdomaincenter,
                        subdomainfinder99, threatminer, tomba, urlscan, venacius, virustotal, whoisxml, yahoo, zoomeye

(kali@kali)~$ theHarvester -d tesla.com -b crtsh,certspotter
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* [ ASCII Art ] *
* [ ASCII Art ] *
* [ ASCII Art ] *
* [ ASCII Art ] *
* [ ASCII Art ] *
* theHarvester 4.8.2 *
* Coded by Christian Martorella *
* Edge-Security Research *
* cmartorella@edge-security.com *
*****

[*] Target: tesla.com

An exception has occurred: 502, message='Attempt to decode JSON with unexpected mimetype: text/html', url='https://crt.sh/?q=%25.tesla.com&exclude=expired&deduplicate=Y&output=json'
[*] Searching CRTsh.
    Searching results.
[*] Searching Certspotter.

[*] No IPs found.

[*] No emails found.

[*] No people found.

[*] Hosts found: 1
*.tesla.com

(kali@kali)~$

```

- During a penetration-testing engagement, assess the publicly accessible web application **testphp.vulnweb.com** using the **Nikto** tool to identify potentially exposed files and directories, insecure HTTP methods, server configuration weaknesses, information-disclosure issues, outdated components, dangerous files, and other potential security weaknesses. For every significant finding, collect appropriate evidence and determine whether it represents a confirmed vulnerability, a configuration weakness, or an issue requiring further manual validation. Prepare a final assessment including the commands used, significant findings, supporting evidence, potential security impact, likelihood of exploitation, recommended remediation measures, methods for validating remediation, and a prioritized list of the most important findings, with particular attention to exposed files, server-version information, directory listings, insecure HTTP methods, and outdated components. **Required Tool: Nikto.**

Ans: 1. Objective

- Assess the authorized web application testphp.vulnweb.com using Nikto.
- Identify common web-server misconfigurations, exposed files, HTTP methods, outdated components, and information disclosure.

2. Tool Used

- Nikto
- Web-server vulnerability and configuration scanner.

3. Basic Command

nikto -h http://testphp.vulnweb.com

Save the scan results:

nikto -h http://testphp.vulnweb.com -o nikto_report.txt

4. Important Findings to Check

Finding	Risk	Classification
Exposed files/directories	High	Validate
Directory listing	Medium/High	Configuration weakness

Finding	Risk	Classification
Server version disclosure	Medium	Information disclosure
Insecure HTTP methods	High	Validate
Outdated components	High	Potential vulnerability
Dangerous/backup files	High	Validate
Missing security headers	Low/Medium	Configuration weakness
Information disclosure	Medium	Configuration weakness

5. Exposed Files and Directories

- Check for backup files, configuration files, test files, and administrative directories.
- Determine whether sensitive information can be accessed without authentication.
- Impact: Information leakage and possible further attacks.

6. Server-Version Information

- Nikto may identify the web server and version.
- **Risk:** Attackers can use the version to search for known vulnerabilities.
- **Classification:** Usually information disclosure; verify whether the version is actually exploitable.

7. Directory Listing

- Check whether directories expose their contents.
- **Risk:** Attackers may discover application files, backups, scripts, or sensitive resources.
- **Classification:** Configuration weakness.

8. Insecure HTTP Methods

Check methods such as:

GET
POST
PUT
DELETE
OPTIONS

TRACE

- Dangerous methods should be manually verified.
- **Risk:** Unauthorized modification or unexpected server behavior.
- **Classification:** Requires manual validation unless exploitation is demonstrated.

9. Outdated Components

- Identify old web-server/software versions reported by Nikto.
- Compare versions with official security advisories.
- **Risk:** Known vulnerabilities may be exploitable.
- **Classification:** Potential vulnerability until confirmed.

10. Evidence to Collect

- Nikto command used.
- Terminal screenshot.
- Finding description.
- Affected URL/path.
- Server/version information.
- HTTP response/status code.
- Relevant Nikto output.
- Manual verification results.

11. Risk Assessment

High Priority

- Sensitive exposed files
- Dangerous backup/configuration files
- Confirmed insecure HTTP methods
- Confirmed vulnerable outdated components

Medium Priority

- Directory listing
- Server-version disclosure
- Other information leakage

Low Priority

- Missing non-critical security headers
- Minor configuration issues

12. Recommended Remediation

- Remove unnecessary files and directories.
- Disable directory listing.
- Disable unnecessary HTTP methods.
- Update outdated server components.
- Hide unnecessary server-version information.
- Remove backup/configuration files from web-accessible locations.
- Implement appropriate security headers.
- Regularly scan and patch the web server.

13. Remediation Validation

After fixing the issues:

nikto -h <http://testphp.vulnweb.com>

Verify that:

- Previously exposed files are no longer accessible.
- Directory listing is disabled.
- Unnecessary HTTP methods are disabled.
- Server information is minimized.
- Outdated components are patched.
- Previously reported findings no longer appear.

14. Final Priority

1. Exposed sensitive/dangerous files
2. Outdated vulnerable components
3. Insecure HTTP methods
4. Directory listing
5. Server-version disclosure
6. Other information-disclosure issues
7. Minor configuration weaknesses

Conclusion

Nikto provides a useful first-level assessment of web-server security. Its findings should be treated as confirmed vulnerabilities, configuration weaknesses, or items requiring manual validation rather than assuming every scanner result is exploitable.

```
kali@kali:~$ zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~$ nikto -Version
Nikto 2.5.0 (LW 2.5)

(kali@kali)~$ curl -I http://testphp.vulnweb.com/
curl: (7) Failed to connect to testphp.vulnweb.com port 80 after 21396 ms: Could not connect to server

(kali@kali)~$ ping -c 4 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data:
64 bytes from 8.8.8.8: icmp_seq=1 ttl=255 time=7.61 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=255 time=9.48 ms
64 bytes from 8.8.8.8: icmp_seq=3 ttl=255 time=8.93 ms

--- 8.8.8.8 ping statistics ---
4 packets transmitted, 3 received, 25% packet loss, time 3007ms
rtt min/avg/max/mdev = 7.612/8.673/9.482/0.784 ms

(kali@kali)~$ ping -c 4 google.com
PING google.com (142.250.77.110) 56(84) bytes of data:
64 bytes from pnmaaa-aq-in-f14.1e100.net (142.250.77.110): icmp_seq=1 ttl=255 time=13.1 ms
64 bytes from pnmaaa-aq-in-f14.1e100.net (142.250.77.110): icmp_seq=2 ttl=255 time=14.2 ms
64 bytes from pnmaaa-aq-in-f14.1e100.net (142.250.77.110): icmp_seq=3 ttl=255 time=14.1 ms
64 bytes from pnmaaa-aq-in-f14.1e100.net (142.250.77.110): icmp_seq=4 ttl=255 time=11.9 ms

--- google.com ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3193ms
rtt min/avg/max/mdev = 11.886/13.321/14.205/0.938 ms

(kali@kali)~$ nslookup testphp.vulnweb.com
Server:      172.21.100.31
Address:     172.21.100.31#53

Non-authoritative answer:
Name:   testphp.vulnweb.com
Address: 44.228.249.3
```

3. A company is conducting an external security assessment to determine whether its DNS infrastructure discloses more information than intended. Using the **Dig** utility against the authorized target domain **zonetransfer.me**, perform a detailed DNS enumeration exercise by identifying and documenting the available A, AAAA, MX, NS, CNAME, TXT, SOA, and other relevant DNS records, determining the authoritative servers, and assessing whether an unauthorized DNS zone transfer can be requested. Analyze the results from an attacker's perspective and explain how DNS records can reveal mail infrastructure, server naming conventions, hostnames, service relationships, and other infrastructure information. Your assessment should identify the DNS records and authoritative servers, determine whether a zone transfer was possible, explain the additional information exposed by a successful zone transfer and the risks of unrestricted AXFR access, discuss how DNS information can be combined with other reconnaissance techniques, recommend appropriate DNS security controls, and explain how remediation can be verified. **Required Tool: Dig.**

Ans: Important Points – DNS Enumeration Using Dig

1. Objective

- Perform DNS enumeration against the authorized target zonetransfer.me.
- Identify DNS records and authoritative name servers.
- Check whether an unauthorized DNS zone transfer (AXFR) is possible.

2. Tool Used

- Dig (Domain Information Groper)
- Used to query DNS records and test DNS configuration.

3. Identify Name Servers

dig zonetransfer.me NS

This identifies the authoritative DNS servers.

4. A Record

dig zonetransfer.me A

- Identifies IPv4 addresses.
- Helps identify publicly reachable infrastructure.

5. AAAA Record

dig zonetransfer.me AAAA

- Identifies IPv6 addresses.

6. MX Record

dig zonetransfer.me MX

- Identifies mail servers.
- Helps reveal the organization's email infrastructure.

7. CNAME Record

dig zonetransfer.me CNAME

- Identifies aliases.
- Can reveal relationships between domains and services.

8. TXT Record

dig zonetransfer.me TXT

- May contain SPF, verification, or other domain information.
- Can provide useful information about third-party services.

9. SOA Record

dig zonetransfer.me SOA

- Identifies the primary authoritative server.
- Provides DNS administrative information such as serial number and refresh settings.

10. Query All Common Records

dig zonetransfer.me ANY

Note: ANY responses are often incomplete or restricted, so individual record queries are more reliable.

11. Test DNS Zone Transfer

First identify the authoritative server:

dig zonetransfer.me NS

Then request an AXFR from an identified authoritative server:

dig AXFR zonetransfer.me @<authoritative-server>

Example format:

dig AXFR zonetransfer.me @ns1.example.com

12. If AXFR Succeeds

A successful transfer may expose:

- All DNS hostnames
- Internal or less-public hosts
- IP addresses
- Mail servers
- Subdomains
- CNAME relationships
- Server naming conventions
- Development/test systems
- Service relationships

13. Security Risk of Unrestricted AXFR

- Provides attackers with a detailed DNS map.
- Reduces the effort required for reconnaissance.
- May reveal hosts that are not intended to be easily discoverable.
- Helps attackers identify potentially interesting services.

- Can be combined with port scanning and vulnerability scanning.

Severity: Usually High when sensitive infrastructure information is exposed.

14. Attacker Perspective

DNS information can be combined with other reconnaissance techniques:

DNS Enumeration



Hostnames + IP addresses



Nmap/service enumeration



Service/version identification



Vulnerability assessment

For example:

MX records → mail server → IP address → service enumeration

DNS hostname → web server → URL discovery → web vulnerability testing

15. Recommended DNS Security Controls

- Restrict AXFR to authorized secondary DNS servers.
- Use DNS ACLs.
- Disable unrestricted zone transfers.
- Use TSIG authentication for authorized transfers.
- Keep internal DNS information separate from public DNS.
- Regularly review DNS records.
- Remove obsolete DNS entries.
- Monitor unusual DNS queries and transfer attempts.

16. Remediation Verification

After restricting zone transfers, repeat:

`dig AXFR zonetransfer.me @<authoritative-server>`

The unauthorized request should be refused or denied.

Also verify that normal DNS queries still work:

`dig zonetransfer.me A`

`dig zonetransfer.me MX`

`dig zonetransfer.me NS`

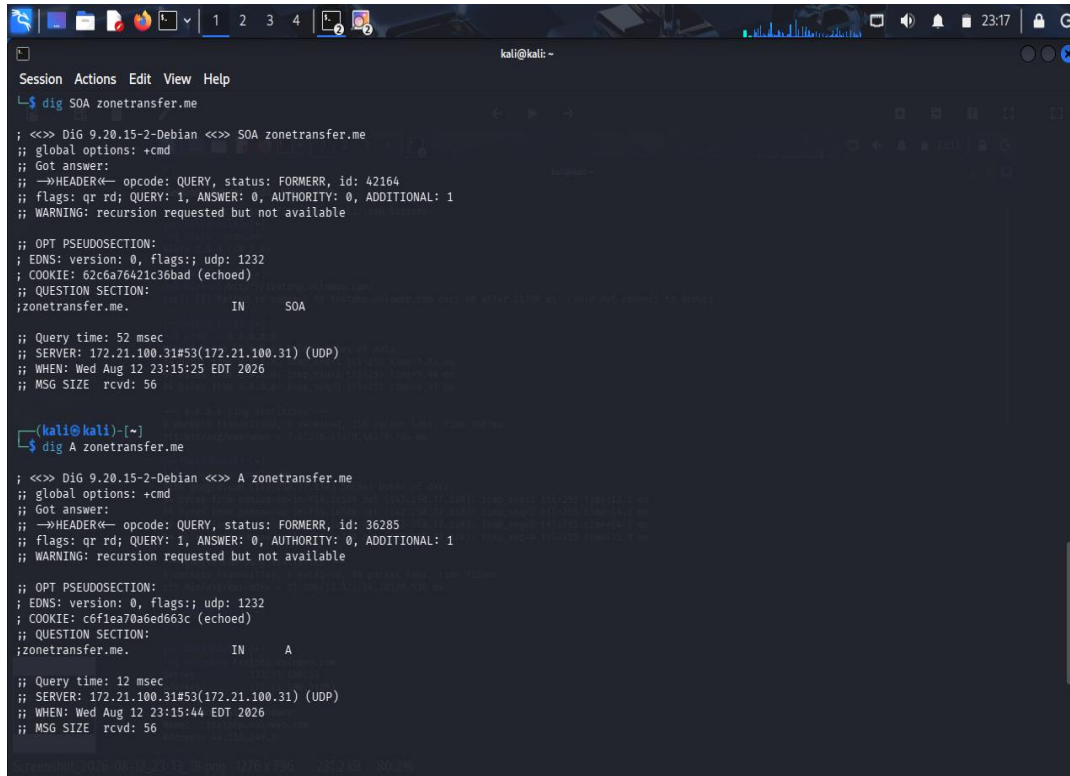
17. Priority of Findings

1. Successful unrestricted AXFR – High
2. Sensitive/internal hosts exposed – High
3. Unexpected DNS records – Medium/High
4. Excessive infrastructure information – Medium

5. Unnecessary/obsolete records – Low/Medium

Conclusion

Dig can provide a clear picture of an organization's DNS infrastructure. A successful unrestricted AXFR is particularly significant because it can disclose a large number of DNS records at once. DNS information should therefore be minimized, regularly reviewed, and protected using ACLs and authenticated zone transfers.



```
kali@kali: ~  
$ dig SOA zonetransfer.me  
  
;<>> Dig 9.20.15-2-Debian <>> SOA zonetransfer.me  
;; global options: +cmd  
;; Got answer:  
;; ->HEADER<- opcode: QUERY, status: FORMERR, id: 42164  
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1  
;; WARNING: recursion requested but not available  
  
;; OPT PSEUDOSECTION:  
;; EDNS: version: 0, flags: udp: 1232  
;; COOKIE: 62c6a76421c36bad (echoed)  
;; QUESTION SECTION:  
;zonetransfer.me.          IN      SOA  
  
;; Query time: 52 msec  
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)  
;; WHEN: Wed Aug 12 23:15:25 EDT 2026  
;; MSG SIZE rcvd: 56  
  
(kali@kali)~  
$ dig A zonetransfer.me  
  
;<>> Dig 9.20.15-2-Debian <>> A zonetransfer.me  
;; global options: +cmd  
;; Got answer:  
;; ->HEADER<- opcode: QUERY, status: FORMERR, id: 36285  
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1  
;; WARNING: recursion requested but not available  
  
;; OPT PSEUDOSECTION:  
;; EDNS: version: 0, flags: udo: 1232  
;; COOKIE: c6f1ea70a6ed663c (echoed)  
;; QUESTION SECTION:  
;zonetransfer.me.          IN      A  
  
;; Query time: 12 msec  
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)  
;; WHEN: Wed Aug 12 23:15:44 EDT 2026  
;; MSG SIZE rcvd: 56
```

4. As part of an internal penetration-testing engagement, assess the authorized Windows/SMB target **192.168.1.100** using **Enum4linux** to determine what information could be obtained through SMB and NetBIOS enumeration before attempting exploitation. Perform comprehensive enumeration to identify available users, groups, shared resources, domain or workgroup information, operating-system details, password-policy information, NetBIOS information, and other exposed SMB configuration details permitted by the target. Analyze the collected information from an attacker's perspective and determine whether it could facilitate credential attacks, privilege escalation, unauthorized access to shared resources, vulnerability identification, or lateral movement. Prepare a report containing the commands used, identified users and groups, discovered shared resources, relevant system and domain information, evidence of anonymous or null-session enumeration, security implications, relationships between accounts, groups and privileges, risks of unnecessarily accessible SMB shares, recommended controls, and a prioritized remediation plan covering SMB configuration, access control, authentication, patching, and network segmentation. **Required Tool: Enum4linux.**

Ans: Important Points – SMB Enumeration Using Enum4linux

1. Objective

- Assess the authorized Windows/SMB target 192.168.1.100.
- Identify information exposed through SMB and NetBIOS before exploitation.
- Determine whether the information could assist credential attacks, privilege escalation, or lateral movement.

2. Tool Used

- Enum4linux

- Used to enumerate Windows/SMB information such as users, groups, shares, domains, and password policies.

3. Basic Enumeration

enum4linux 192.168.1.100

For more comprehensive enumeration:

enum4linux -a 192.168.1.100

Save the output:

enum4linux -a 192.168.1.100 | tee enum4linux_report.txt

4. Important Information to Collect

Information	Security Importance
Users	May support credential attacks
Groups	Helps identify privileges
Shared folders	May expose sensitive data
Domain/workgroup	Reveals network structure
OS details	Helps vulnerability identification
Password policy	Helps assess authentication security
NetBIOS names	Identifies Windows systems
SMB configuration	Reveals security weaknesses

5. User Enumeration

Look for:

Username

Full Name

Description

Account status

Risk:

- Helps attackers identify valid accounts.
- May support password-spraying or other authorized credential testing.

6. Group Enumeration

Identify groups such as:

Administrators

Users

Remote Desktop Users

Backup Operators

Risk:

- Shows relationships between accounts and privileges.
- Misconfigured group membership can lead to privilege escalation.

7. Share Enumeration

Identify accessible shares such as:

ADMIN\$

C\$

IPC\$

Public

Shared

Determine:

- Share name
- Description
- Access permissions

- Whether anonymous access is allowed
- Risk:**
- Sensitive files may be exposed.
 - Excessive write permissions can increase security risk.

8. Null/Anonymous Session

Check whether SMB permits enumeration without valid credentials.

Evidence may include:

Anonymous access permitted

Null session allowed

Users/shares obtained without authentication

Risk: High if sensitive information can be obtained anonymously.

9. Domain and Workgroup Information

Collect:

- Domain name
- Workgroup name
- Domain controller information
- Server name
- NetBIOS name

Risk:

- Helps attackers understand the Windows network structure.
- Can support later authorized lateral-movement testing.

10. Password Policy

Look for:

- Minimum password length
- Password complexity
- Password expiration
- Account lockout policy

Risk:

- Weak policies can increase susceptibility to password attacks.

11. OS and SMB Information

Identify:

- Windows version
- SMB version/configuration
- Server name
- NetBIOS information

Risk:

- Helps identify outdated systems and potential vulnerabilities.
- Provides useful information for vulnerability assessment.

12. Attacker Perspective

Information can be combined as:

Users

↓

Groups + privileges

↓

Password policy



Accessible SMB shares



OS/SMB information



Credential and vulnerability assessment

This can potentially facilitate:

- Credential attacks
- Privilege escalation
- Unauthorized file access
- Vulnerability identification
- Lateral movement

13. Recommended Security Controls

- Disable unnecessary SMB services.
- Restrict SMB access to trusted networks.
- Disable anonymous/null-session access.
- Apply least-privilege permissions to shares.
- Remove unnecessary shared folders.
- Use strong password policies.
- Enable MFA where appropriate.
- Keep Windows and SMB components patched.
- Monitor failed authentication attempts.
- Restrict administrative shares.
- Segment critical systems using firewalls/VLANs.

14. Prioritized Remediation

Priority 1 – Critical

- Disable unauthorized anonymous/null sessions.
- Remove publicly/unnecessarily accessible sensitive shares.
- Correct excessive administrator privileges.

Priority 2 – High

- Patch outdated Windows systems.
- Restrict SMB network access.
- Strengthen authentication and password policies.

Priority 3 – Medium

- Review users and group memberships.
- Remove unused accounts.
- Remove unnecessary SMB shares.

Priority 4 – Low

- Reduce unnecessary NetBIOS/SMB information disclosure.
- Improve monitoring and logging.

15. Evidence to Include

- Enum4linux command used.
- Terminal screenshot.
- Enumerated users.

- Groups and memberships.
- SMB shares.
- Domain/workgroup information.
- Password policy.
- OS/NetBIOS information.
- Evidence of anonymous/null-session access.
- Risk classification.

Conclusion

Enum4linux helps identify information exposed by Windows SMB services before exploitation. Users, groups, shares, password policies, domain information, and SMB configuration can collectively provide an attacker with valuable information for credential attacks, privilege escalation, and lateral movement. The highest priorities are restricting anonymous access, securing SMB shares, applying least privilege, patching Windows systems, and limiting SMB traffic through network segmentation.

```
kali@kali: ~
Session Actions Edit View Help
Dependency info: You will need to have the samba package installed as this
script is basically just a wrapper around rpcclient, net, nmblookup and
smbclient. Polenum from http://labs.portcullis.co.uk/application/polenum/
is required to get Password Policy info.

(kali@kali)-[~]
└─$ ping -c 4 192.168.1.100
PING 192.168.1.100 (192.168.1.100) 56(84) bytes of data.

--- 192.168.1.100 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3068ms

(kali@kali)-[~]
└─$ enum4linux 192.168.1.100
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Wed Aug 12 23:19:14 2026

----- ( Target Information ) -----
Target ..... 192.168.1.100
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

----- ( Enumerating Workgroup/Domain on 192.168.1.100 ) -----

[E] Can't find workgroup/domain

----- ( Nbtstat Information for 192.168.1.100 ) -----
Looking up status of 192.168.1.100
No reply from 192.168.1.100

----- ( Session Check on 192.168.1.100 ) -----

[E] Server doesn't allow session using username '', password ''. Aborting remainder of tests.
```

5. During an external penetration-testing engagement, assess the authorized target **scanme.nmap.org** using **Netcat (nc)** to connect to accessible TCP services and collect service responses and banner information. Analyze the responses to determine what technical information the target voluntarily discloses, including service type, protocol, software name, version information, HTTP response headers, operating-system clues, and other implementation details. For each significant observation, explain what information was disclosed, which service provided it, how it could assist an attacker with fingerprinting, whether version information could be correlated with known vulnerabilities, whether the finding represents a vulnerability or merely information disclosure, what additional validation is required, and what remediation measures could reduce unnecessary exposure. Finally, explain how the organization should monitor and periodically reassess externally exposed services and discuss the security implications of service-banner exposure and how accurate service fingerprinting can make subsequent attacks more targeted. **Required Tool: Netcat (nc).**

Ans: Important Points – Service Enumeration Using Netcat

1. Objective

- Assess the authorized target scanme.nmap.org using Netcat (nc).
- Identify accessible TCP services and collect service/banner information.
- Determine what technical information is voluntarily disclosed.

2. Tool Used

- Netcat (nc)
- Used to establish TCP connections and manually inspect service responses.

3. Basic Connection

nc -v scanme.nmap.org 80

Then send an HTTP request:

GET / HTTP/1.1

Host: scanme.nmap.org

Connection: close

For another known TCP service:

nc -v scanme.nmap.org <PORT>

4. Important Information to Collect

Information	Importance
Open TCP service	Identifies accessible service
Service type	Helps fingerprint the system
Software name	Identifies implementation
Version	Can be correlated with known vulnerabilities
HTTP headers	May reveal server technology
OS clues	Helps fingerprint target
Protocol response	Reveals implementation details

5. HTTP Banner Information

Use:

nc -v scanme.nmap.org 80

Send:

HEAD / HTTP/1.1

Host: scanme.nmap.org

Connection: close

Look for headers such as:

Server:

Date:

Content-Type:

Content-Length:

6. Service Fingerprinting

A service may disclose:

- Service name
- Protocol
- Software product
- Version number
- Supported protocol features

Risk: Attackers can use this information to identify the technologies running on the target.

7. Version Information

If a banner provides a specific software version:

Software → Version → Known vulnerabilities

The version should be compared with trusted vulnerability databases and vendor advisories.

Important: Version disclosure alone is generally an information-disclosure issue, not proof of a vulnerability.

8. Operating-System Clues

Possible clues can come from:

- HTTP headers
- Error messages
- Protocol responses
- Connection behavior
- Service implementation details

Risk: Helps attackers narrow down the target's operating system and technology stack.

9. Security Impact

Accurate fingerprinting can help attackers:

- Select appropriate exploits.
- Identify outdated software.
- Target specific services.
- Reduce trial-and-error.
- Plan more focused attacks.

10. Finding Classification

Information Disclosure

- Server name/version exposed.
- HTTP technology information exposed.

Potential Vulnerability

- An exposed version is known to contain security vulnerabilities.

Confirmed Vulnerability

- Requires authorized testing to demonstrate actual exploitable behavior.

11. Additional Validation

For each finding:

1. Confirm the service is actually running.
2. Verify the reported software/version.
3. Compare the version with vendor advisories.
4. Determine whether the vulnerability applies to the configuration.
5. Perform controlled validation within the engagement scope.

12. Recommended Remediation

- Remove unnecessary services.
- Disable unnecessary external ports.
- Minimize server-version banners.
- Avoid unnecessary technology disclosure in HTTP headers.
- Keep exposed services patched.
- Use firewalls to restrict access.
- Apply network segmentation.
- Monitor externally exposed services.

13. Monitoring

Organizations should periodically:

- Scan their Internet-facing IP addresses.
- Review open TCP ports.
- Identify unexpected services.
- Check software versions.
- Monitor configuration changes.
- Remove unused services.
- Reassess after infrastructure changes.

14. Evidence to Include

- Netcat command used.
- Connection output.
- Service response/banner.
- HTTP headers.
- Service/port identified.
- Software/version information.
- Risk classification.
- Screenshots of terminal output.

15. Priority

1. Exposed vulnerable service – Critical/High
2. Outdated software – High
3. Unnecessary Internet-facing service – High
4. Detailed software/version disclosure – Medium
5. Minor HTTP information disclosure – Low/Medium

Conclusion

Netcat allows an assessor to directly observe responses from accessible TCP services. Service banners and HTTP headers can reveal service type, software, versions, and implementation details, helping attackers perform accurate fingerprinting. Banner exposure is normally an information-disclosure issue, but it becomes more significant when the disclosed version is associated with a known vulnerability. Organizations should minimize unnecessary services and information disclosure, keep exposed software patched, and continuously monitor their external attack surface.

[illegible]

Code of Conduct:

I __k. Venkata Karthik /192372092 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: K. Venkata Karthik

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Task	20				
Procedure & Execution	25				
Observation & Result	20				
Viva Voce / Conceptual Response	20				
Time Management & Presentation	15				

Criteria	Understanding of Task	Procedure & Execution	Observation & Result	Viva Voce / Conceptual Response	Time Management & Presentation
Weightage	20 (2)	25 (3)	20 (2)	20 (2)	15 (1)
Q1					
Q2					
Q3					
Q4					
Q5					